Evidence-Based Environmental CVSS v4.0 Prioritization

An Explainable AI Watcher Architecture with Grounded Telemetry and Human-in-the-Loop Governance

Wagner Santos

SecOps Research Lead, HelpUS Security Group

wagner@helpusbr.com

Comprehensive Technical Reference Monograph & Companion Book

Prepared for IEEE International Conference on AI in Cybersecurity (ICAIC 2027) Submissions

October 2026

Contents

Executive Summary vi

1 Introduction: The Vulnerability Prioritization Crisis 1
- 1.1 The Threat Landscape and Alert Fatigue . . . 1
- 1.2 The Dilemma of Intrinsic Severity vs. Operational Context . . . 2
- 1.3 The HelpUS Solution and Research Objectives . . . 2

2 FIRST CVSS v4.0 Specification and Theoretical Foundations 4
- 2.1 Evolution of Vulnerability Metrics: CVSS v2 to v4.0 . . . 4
- 2.2 Environmental Vector Decomposition . . . 4
  - 2.2.1 Modified Base Metrics . . . 4
  - 2.2.2 Security Requirements (CR, IR, AR) . . . 5
- 2.3 The Mathematical Formula and Macro-Vectors . . . 5
- 2.4 Historical Evidence on Human Difficulty in Environmental Scoring . . . 6

3 Architecture of the HelpUS AI Watcher Engine 8
- 3.1 System Architecture Overview . . . 8
- 3.2 The Tripartite Evidence Contract . . . 8
- 3.3 Two-Stage Deterministic Prioritization Pipeline . . . 8
- 3.4 Formal Topological Inference for Modified Attack Vector (MAV) . . . 9
  - 3.4.1 Conservative Fail-Safe and Abstention Policy . . . 10
- 3.5 Exact Combinatorial Optimization for What-If Target Remediation . . . 10
  - 3.5.1 Exact Global Optimality via Exhaustive State Enumeration . . . 11
- 3.6 Policy-as-Code Virtual Patching Synthesis . . . 11
- 3.7 Exploratory Reachability-Adjusted EPSS Model (Future Work) . . . 12

4 Dynamic Network Scanning and Topology Inference 13
- 4.1 Real-Time Discovery Pipeline . . . 13
- 4.2 Topology Inference and Attack Surface Mapping . . . 13
  - 4.2.1 Exposure Classification Logic . . . 13
- 4.3 Throughput and Latency Performance . . . 14
- 4.4 Next-Generation Firewall (NGFW) Telemetry Ingestion . . . 14

5 Human-in-the-Loop (HITL) Governance and Regulatory Alignment 15
- 5.1 The Imperative of Human Oversight in AI Security Systems . . . 15
- 5.2 The 4-Step Homologation Workflow Protocol . . . 15
  - 5.2.1 Formal Audit Hash Generation and Merkle Chain . . . 15
- 5.3 Configurable Operational SLA Policy . . . 16
  - 5.3.1 Economic Modeling as Future Calibration Work . . . 16

6 Empirical Evaluation and 30-Scenario Benchmark **18**
6.1 Benchmark Dataset Architecture and Roles . . . 18
6.2 Distinction Between CVSS Severity and Operational Priority . . . 18
6.3 Statistical Results on Development Benchmark (Dataset B) . . . 19
6.3.1 Formal Evaluation Metric Formulations . . . 19
6.3.2 Resolution of the Infrastructure Attribution Failure . . . 20

7 Real-World Operational Case Studies **21**
7.1 Case Study 1: Core Banking PCI-DSS Payment Gateway . . . 21
7.1.1 Context and Architecture . . . 21
7.1.2 Environmental Telemetry . . . 21
7.1.3 HelpUS Evaluation vs. Legacy Scoring . . . 21
7.2 Case Study 2: Network-Isolated Medical Clinic Workstation . . . 22
7.2.1 Context and Architecture . . . 22
7.2.2 Environmental Telemetry . . . 22
7.2.3 HelpUS Evaluation vs. Legacy Scoring . . . 22
7.3 Case Study 3: Public Cloud E-Commerce Storefront . . . 22
7.3.1 Context and Architecture . . . 22
7.3.2 HelpUS Evaluation . . . 22
7.4 Case Study 4: Enterprise Infrastructure — Resolving the Cisco Switch Dilemma 22
7.4.1 The Dilemma Identified in Empirical Literature . . . 22
7.4.2 HelpUS Topological Graph Evaluation . . . 23
7.4.3 Contextual Vector Computation . . . 23
7.4.4 Policy-as-Code Virtual Patching and What-If Optimization . . . 23

8 Optional Cognitive Assurance Layer **25**
8.1 Architectural Separation . . . 25
8.2 Operating Modes . . . 25
8.3 Package and Return Contracts . . . 25
8.4 Multi-Model Review . . . 26
8.5 Graceful Degradation . . . 26
8.6 Security and Privacy . . . 26
8.7 Scientific Evaluation . . . 26
8.8 Product Modularity . . . 27

9 Discussion, Threats to Validity, and Conclusion **28**
9.1 Discussion of Practical Implications . . . 28
9.2 Threats to Validity . . . 28
9.2.1 Construct Validity . . . 28
9.2.2 Internal Validity . . . 28
9.2.3 External Validity . . . 29
9.2.4 Conclusion Validity . . . 29
9.3 Conclusion and Future Research . . . 29

A Canonical PCI-DSS Enterprise Scenarios **31**
A.1 Scenario 1: Joe's Jumping Jerky Joint (Merchant Level 3) . . . 31
A.1.1 Organizational Context and Compliance Scope . . . 31
A.1.2 Architectural Remediation (After Compliance) . . . 31
A.2 Scenario 2: Christine's Enterprise (Merchant Level 1) . . . 33
A.2.1 Organizational Context and Core Switching Architecture . . . 33
A.2.2 Multi-VLAN Remediation and RACL Enforcement . . . 33

B Statistical Methodology and Replication Analysis **35**
B.1 Hypothesis Formulation and Fisher's Exact Test 35
B.1.1 Network Complexity Hypothesis ($H2$) 35
B.2 Permutation Two-Way ANOVA for Co-Factor Invariance 36
B.3 Monte Carlo Dispersal Simulation Algorithm 36

C Complete Experimental Datasets **38**
C.1 Historical 2017 Vulnerability Corpus (Allodi et al.) 38
C.2 Dataset B: 30-Scenario Development Benchmark 40

List of Figures

1.1 Dataset B development composition shown without conflating CVSS severity with local policy. The left group identifies scenario origin (12 real-CVE records embedded in controlled contexts and 18 synthetic fixtures); the right group shows legacy local P0–P4 development-policy dispositions. The chart is descriptive development evidence only; it is not an accuracy, false-positive, or held-out validation result. 1

5.1 The HelpUS 4-Step Human-in-the-Loop Homologation Pipeline. 16

A.1 Architecture of the Level 3 merchant network (Joe's Jumping Jerky Joint) before and after PCI-DSS network segmentation and DMZ enforcement [1, 2]. 32

A.2 Architecture of the multi-tier enterprise network (Christine's Company) before and after core multi-VLAN segmentation and Router Access Control Lists (RACLs) [1, 2]. 34

List of Tables

3.1 Evidence-oriented reachability conditions for candidate Modified Attack Vector (MAV) recommendations. FIRST remains the normative semantic source. . . 10

6.1 Dataset B development composition by scenario origin and legacy local operational disposition ($n = 30$). P0–P4 are organization-policy workflow labels, not CVSS severity levels. 19
6.2 Replication-Inspired Benchmark: Historical Human Error Rates [1] and Development-Stage HelpUS Scenario Outputs 20

B.1 Contingency Table of Assessment Correctness by Network Complexity 35

C.1 Historical Vulnerability Dataset from the Allodi et al. [1] Empirical Trial . . . 39
C.2 Dataset B real-CVE source-assessment provenance (12 development scenarios). Provider-reported Base values are kept distinct from scores recomputed from the complete source vector. Full-vector recomputation remains provisional until calculator gate G1 reaches zero unexplained FIRST-reference mismatches. . . 41
C.3 Dataset B synthetic development scenarios (18 fixtures). The legacy assigned score is retained for provenance; the current vector recomputation exposes inconsistencies that must be resolved after calculator gate G1 closes. Synthetic inputs are investigator-authored and are not CNA/NVD-published assessments. 42

Executive Summary

This research monograph provides a comprehensive mathematical, architectural, and empirical reference for automated vulnerability prioritization under the FIRST Common Vulnerability Scoring System (CVSS) v4.0 specification.

Addressing the operational limitations of using source CVSS assessments without organization-specific context, we introduce the HelpUS Framework: a system integrating network-topology evidence, an explainable evidence-constrained deterministic inference pipeline, specification-conformant CVSS v4.0 scoring, and a Human-in-the-Loop (HITL) review gate. The governance workflow is designed to support auditability and human oversight; it does not by itself establish compliance with NIST, ISO, PCI-DSS, or other frameworks.

The current 30-scenario Dataset B is a development benchmark used for architectural verification and regression testing; it is not confirmatory evidence of external generalization. A pinned FIRST calculator reference corpus has been fully verified across all 486,472 test cases against official FIRST commit d766d0c8ab4368b67bf27dd0e411eb481f05fdbb with zero mismatches, successfully closing the calculator conformance gate (G1). Dataset B source provenance has been migrated to a schema that separates provider-reported Base values from scores recomputed from full source vectors, and all manuscript tables must be regenerated from that canonical source before freeze. Engine-level timing measurements are reported separately from historical human-session timings and are not treated as a like-for-like end-to-end speedup. Confirmatory claims remain pending independent held-out evaluation (Datasets C1/C2), expert adjudication, and applicable ethics determination. Web-layer audit-receipt canonicalization and authorization controls remain separate engineering claims that require their own conformance and security evidence.

Chapter 1

Introduction: The Vulnerability Prioritization Crisis

1.1 The Threat Landscape and Alert Fatigue

In contemporary enterprise architectures, vulnerability management programs are confronted with an unprecedented volume of Common Vulnerabilities and Exposures (CVEs). Organizations routinely receive tens of thousands of automated scanner findings per month. In practice, operational security teams (SecOps) cannot patch all reported defects within typical service level agreements (SLAs).

The primary challenge lies in **alert inflation**: conventional scanners evaluate vulnerability severity based heavily on source CVSS assessments published by vulnerability authorities and commonly indexed by services such as the National Vulnerability Database (NVD) [3]. A remote code execution (RCE) defect assigned a CVSS Base score of 9.8 is treated as an existential emergency regardless of whether the affected host is an edge-facing payment gateway or an isolated development sandbox accessible only over a local loopback interface.

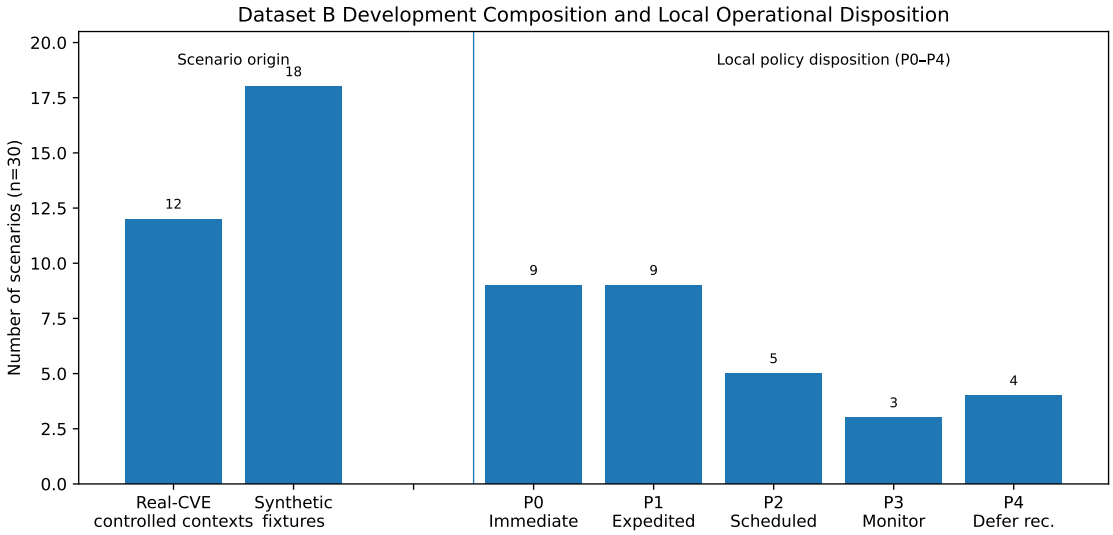


Figure 1.1: Dataset B development composition shown without conflating CVSS severity with local policy. The left group identifies scenario origin (12 real-CVE records embedded in controlled contexts and 18 synthetic fixtures); the right group shows legacy local P0–P4 development-policy dispositions. The chart is descriptive development evidence only; it is not an accuracy, false-positive, or held-out validation result.

1.2 The Dilemma of Intrinsic Severity vs. Operational Context

The fundamental mathematical and semantic boundary of vulnerability management is delineated by two concepts:

1. **Base Severity ($S_{\mathbf{base}}$):** Represents vulnerability characteristics that are intended to remain independent of a specific organization's environment. Local compensating controls and business requirements are deliberately outside the Base metric group.

2. **Contextual Environmental Severity ($S_{\mathbf{env}}$):** Represents a CVSS Environmental result after organization-specific modified metrics and security requirements have been documented. It is a contextual severity score, not a complete probabilistic risk estimate.

FIRST CVSS v4.0 defines Environmental metrics so that local conditions can be represented explicitly. Applying those metrics at scale may require analysts to reconcile vulnerability records with topology, reachability, asset requirements, and compensating controls. Prior empirical work shows that such contextual assessment becomes error-prone in complex network scenarios [1]. This work therefore studies whether verified operational evidence can support a more reproducible and auditable recommendation process.

1.3 The HelpUS Solution and Research Objectives

This work introduces the **HelpUS CVSS Framework**, an evidence-grounded decision architecture that derives *candidate* CVSS v4.0 Environmental metrics from verified operational evidence and then delegates numerical scoring to a specification-conformant CVSS v4.0 calculator.

Our core contributions are structured as follows:

- **Tripartite Evidence Contract:** Preservation of the source CVSS assessment vector and nomenclature alongside the contextual result and its provenance, supporting auditability without overwriting the original assessment.

- **Deterministic AI Watcher:** An evidence-constrained inference layer that recommends candidate Environmental metrics and abstains when the evidence is incomplete or contradictory.

- **Inverse Environmental Optimization (What-If Solver):** A constrained combinatorial solver that deduces the minimal set of compensating controls required to meet organizational risk thresholds.

- **Policy-as-Code Virtual Patching:** Synthesis of candidate Linux `iptables`, cloud security-group, and WAF controls that require validation and Human-in-the-Loop approval before production deployment.

- **Reachability-Adjusted EPSS Heuristic:** A clearly labeled heuristic for combining global exploit-likelihood information with local reachability evidence; it is not presented as a calibrated posterior probability.

- **Human-in-the-Loop (HITL) Governance & SLA Clock:** An auditable 4-step review workflow designed to support organizational governance and alignment with relevant NIST/ISO practices, with tamper-evident provenance and configurable SLA policy.

- **Empirical Scientific Benchmark:** A 30-scenario preliminary benchmark reporting priority redistribution, traceability, abstention behavior, and engine-level latency; accuracy claims require an independently adjudicated expert reference set.

Chapter 2

FIRST CVSS v4.0 Specification and Theoretical Foundations

2.1 Evolution of Vulnerability Metrics: CVSS v2 to v4.0

The Common Vulnerability Scoring System (CVSS), maintained by the Forum of Incident Response and Security Teams (FIRST), represents the global standard for vulnerability characterization [3]. While CVSS v2 and v3.1 provided foundational metrics, they suffered from significant metric compression and inadequate separation between threat intelligence and environmental mitigations.

In CVSS v4.0, FIRST established a strict taxonomy comprising four distinct nomenclature groups:

- **CVSS-B (Base):** Measures intrinsic qualities that are constant over time and across user environments.
- **CVSS-BT (Base + Threat):** Factors in temporal exploit maturity (Attacked, Proof-of-Concept, Unreported).
- **CVSS-BE (Base + Environmental):** Factors in local system characteristics, compensating mitigations, and organizational requirements.
- **CVSS-BTE (Base + Threat + Environmental):** The comprehensive score incorporating all metric groups.

2.2 Environmental Vector Decomposition

The environmental metric group modifies Base metrics according to the defensive reality of the target asset. The formal environmental metric vector comprises two primary subsets:

2.2.1 Modified Base Metrics

Defenders alter the base vector when local architectural controls change the attack surface:

$$\text{Vector}_{\text{modified}} = \{\text{MAV}, \text{MAC}, \text{MAT}, \text{MPR}, \text{MUI}, \text{MVC}, \text{MVI}, \text{MVA}, \text{MSC}, \text{MSI}, \text{MSA}\} \quad (2.1)$$

Among these, the **Modified Attack Vector (MAV)** represents the most impactful lever in segmented infrastructure:

- MAV:Network (N) → Exploitation can be performed remotely through a network protocol stack; the attacker may be one or more network hops away. Internet exposure is one possible case, but is not required.
- MAV:Adjacent (A) → Exploitation requires access to a logically or physically adjacent network context, such as the same constrained broadcast or proximity domain.
- MAV:Local (L) → Exploitation requires local access to the vulnerable system or a local execution context; this is distinct from physical manipulation.
- MAV:Physical (P) → Exploitation requires physical interaction with the vulnerable component. The authoritative FIRST specification remains the normative definition [3].

2.2.2 Security Requirements (CR, IR, AR)

Security Requirements customize the impact based on the asset's business criticality and regulatory classification:

$$\text{CR} \in \{\text{High}, \text{Medium}, \text{Low}, \text{Not Defined}\} \tag{2.2}$$

$$\text{IR} \in \{\text{High}, \text{Medium}, \text{Low}, \text{Not Defined}\} \tag{2.3}$$

$$\text{AR} \in \{\text{High}, \text{Medium}, \text{Low}, \text{Not Defined}\} \tag{2.4}$$

Security Requirements are organization-specific. Regulatory or business scope (including PCI-DSS) may inform a documented organizational mapping policy, but the external standard does not by itself mandate particular CVSS values such as CR:High or IR:High. Any such mapping in HelpUS must therefore be explicit, reviewable, and attributable to local policy.

2.3 The Mathematical Formula and Macro-Vectors

Unlike CVSS v3.1, CVSS v4.0 uses a MacroVector lookup-and-interpolation architecture [3]. The equivalence groups defined by FIRST are not a simple one-to-one partition of the named Base, Threat, and Environmental metric groups. The normative grouping is:

- EQ_1: AV / PR / UI.
- EQ_2: AC / AT.
- EQ_3: VC / VI / VA.
- EQ_4: SC / SI / SA.
- EQ_5: E (Exploit Maturity).
- EQ_6: the vulnerable-system impact metrics VC / VI / VA evaluated together with the Environmental Security Requirements CR / IR / AR.

FIRST further specifies that EQ_3 and EQ_6 are not independent and are considered jointly during MacroVector scoring. Modified Environmental metrics influence the effective metric values used by the scoring process; they should not be described as a separate serialized "EQ6 modified-impact" group. The FIRST specification remains the normative source for the boolean level definitions and interpolation algorithm [3].

The calculated environmental score S_{env} is bounded by:

$$0.0 \leq S_{\text{env}} \leq 10.0 \tag{2.5}$$

The score variation Δ between the source score S_{source} and the contextual environmental score is defined as:

$$\Delta = S_{\text{env}} - S_{\text{source}} \tag{2.6}$$

A negative Δ indicates that the contextual CVSS result is numerically lower than the source score, whereas a positive Δ indicates a higher contextual result. Neither direction, by itself, establishes operational risk acceptance, regulatory status, or correctness.

2.4 Historical Evidence on Human Difficulty in Environmental Scoring

Environmental scoring requires assessors to combine vulnerability semantics with organization-specific system and network context. Allodi et al. [1] studied this assessment difficulty in a controlled 2017 experiment involving $n = 29$ MSc students and enterprise network layouts derived from PCI-DSS compliance literature [2]. The study predates CVSS v4.0 and therefore serves here as a historical human-factors baseline rather than a v4.0 ground truth.

The empirical findings reported by Allodi et al. [1] provide three observations that motivate the HelpUS architecture:

1. **Network Complexity Destroys Human Accuracy ($H2_0$ Rejected):** In a simple, flat network layout, human participants achieved an acceptable correctness rate of 83% (96/116 correct scores). However, once network segmentation was introduced to satisfy PCI-DSS scoping requirements (VLANs, DMZs, and access control lists), the human correctness rate collapsed to 59% (136/232 correct). Fisher's exact test confirmed the overwhelming statistical significance of this degradation:

$$p = 4.2 \times 10^{-6}, \quad \text{Odds Ratio} = 3.4, \quad 95\%\ \text{CI} = [1.91, 6.18] \tag{2.7}$$

   Human analysts are over three times more likely to miscalculate environmental scores in a modern segmented architecture than in an obsolete flat network.

2. **System and Infrastructure Vulnerabilities Induce Severe Error ($H1_0$ Rejected):** The experiment revealed a profound disparity between application-level vulnerabilities (APP) and system/infrastructure-level vulnerabilities (SYS). In segmented networks, application vulnerabilities (e.g., browser or office suites) maintained a 72.4% correctness rate, whereas system-level vulnerabilities (e.g., Windows RDP and Cisco core switches) suffered a disastrous error rate of 55.2% ($p = 3.2 \times 10^{-5}$, Odds Ratio = 3.2).

   Most critically, for core network switches implementing Access Control Lists on top of VLANs (specifically Cisco IOS defects CVE-2016-6441 and CVE-2016-6428), **between 86% and 90% of human assessors made critical scoring errors**. Human analysts consistently failed to comprehend whether a vulnerable routing appliance acts as an attack target or as a protective boundary for systems behind it.

3. **Synthetic Score-Space Sensitivity:** A Monte Carlo simulation of 10,000 sampled Environmental metric combinations illustrates that different contextual assumptions can produce a broad score space. This simulation is a sensitivity illustration only; it does not measure human fatigue or reproduce the empirical participant distribution in Allodi et al. The simulation is therefore treated as a separate sensitivity exercise rather than evidence about participant behavior.

Allodi et al. [1] concluded with an explicit challenge to the research community: because network topologies cannot be simplified without sacrificing security, **environmental vulnerability assessment cannot scale without automated data integration and automated topological reasoning engines**.

The HelpUS AI Watcher framework was engineered specifically to solve the challenge formulated by Allodi et al., replacing manual guesswork with deterministic symbolic reasoning .

Chapter 3

Architecture of the HelpUS AI Watcher Engine

3.1 System Architecture Overview

The HelpUS framework operates as an automated bridge between network telemetry and vulnerability prioritization. Its design goal is to constrain metric recommendations to explicit evidence and deterministic rules. Generative components, when used for explanation or interface assistance, are not permitted to alter the CVSS vector without the same evidence checks and review policy. The earlier radar-style "maturity benchmark" has been removed because heterogeneous dimensions such as traceability, speed, and governance do not share a defensible common percentage scale.

3.2 The Tripartite Evidence Contract

A foundational principle of the HelpUS engine is that the source CVSS assessment (including its vector, nomenclature, provider, and reported score semantics) must never be overwritten, hidden, or artificially compressed. Instead, every assessment produces a **Tripartite Evidence Contract** represented formally by the tuple:

$$\mathcal{C} = \langle \mathcal{O}_{\text{source}}, \mathcal{E}_{\text{context}}, \mathcal{V}_{\text{evidence}} \rangle \tag{3.1}$$

where:

- $\mathcal{O}_{\text{source}} = \{S_{\text{source}}, \text{Severity}_{\text{source}}, \mathbf{v}_{\text{source}}, \text{Provider}, \text{Nomenclature}\}$ preserves the source assessment and provenance without implying that NVD, a CNA, or FIRST authored every displayed score.
- $\mathcal{E}_{\text{context}} = \{S_{\text{env}}, \text{Severity}_{\text{env}}, \mathbf{v}_{\text{env}}, \Delta_{\text{score}}, \Delta_{\text{sev}}, \text{Provenance}, \mathcal{K}_{\text{citations}}\}$ specifies the derived contextual CVSS result; operational disposition is produced separately by a versioned organizational policy.
- $\mathcal{V}_{\text{evidence}} = \{I_{\text{route}}, N_{\text{vlan}}, F_{\text{acl}}, P_{\text{compliance}}, C_{\text{compensating}}, B_{\text{criticality}}\}$ documents the verified state of operational controls.

3.3 Two-Stage Deterministic Prioritization Pipeline

Contrary to naive heuristics that apply arbitrary static deltas to base scores, the HelpUS engine strictly decouples **symbolic metric inference** from **standard score computation**. The architecture functions as a two-stage deterministic pipeline:

1. **Stage 1: Evidence-Grounded Metric Deduction:** The engine maps physical and logical network telemetry into candidate CVSS v4.0 environmental metrics (MAV, MAC, MPR, CR, IR, AR).
2. **Stage 2: Specification-Conformant CVSS v4.0 Scoring:** Candidate Environmental metrics are combined with the preserved source vector to construct a valid CVSS v4.0 vector. Numerical scoring is delegated to a pinned calculator implementation whose behavior must be validated against FIRST reference resources before confirmatory evaluation [3].

Algorithm 1 formalizes this two-stage process. The observed delta $\Delta_{\text{score}} = S_{\text{env}} - S_{\text{source}}$ is strictly an emergent mathematical consequence of the FIRST specification, never an ad-hoc arithmetic rule.

Algorithm 1 Evidence-Grounded CVSS v4.0 Environmental Metric Inference

Require: Source CVSS vector $\mathbf{v}_{\text{source}}$, versioned evidence $\mathcal{V}_{\text{evidence}}$, topology graph $\mathcal{G}$, organizational policy Π
Ensure: Either `HUMAN_REVIEW_REQUIRED`, or canonical contextual vector $\mathbf{v}_{\text{env}}$ and score S_{env}

$\mathcal{K} \leftarrow \emptyset$
if Missing($\mathcal{V}_{\text{evidence}}$) $\vee$ Stale($\mathcal{V}_{\text{evidence}}$) $\vee$ Insufficient($\mathcal{V}_{\text{evidence}}$) $\vee$ Conflicting($\mathcal{V}_{\text{evidence}}$) **then**
  return `HUMAN_REVIEW_REQUIRED`
end if
$\mathbf{v}_{\text{cand}} \leftarrow$ ExtractCandidateEnvironmentalMetrics($\mathbf{v}_{\text{source}}$) ▷ Topology-aware candidate MAV
if RequiresPhysicalInteraction($h, \mathcal{V}_{\text{evidence}}$) **then**
  $\mathbf{v}_{\text{cand}}$.MAV $\leftarrow$ Physical
  $\mathcal{K} \leftarrow \mathcal{K} \cup$ {"MAV:P - physical interaction required"}
else if IsLoopbackOrLocalOnly($h, \mathcal{V}_{\text{evidence}}$) **then**
  $\mathbf{v}_{\text{cand}}$.MAV $\leftarrow$ Local
  $\mathcal{K} \leftarrow \mathcal{K} \cup$ {"MAV:L - local execution/access required"}
else if IsAdjacentOnlyDomain($h, \mathcal{G}$) **then**
  $\mathbf{v}_{\text{cand}}$.MAV $\leftarrow$ Adjacent
  $\mathcal{K} \leftarrow \mathcal{K} \cup$ {"MAV:A - verified adjacent-only domain"}
else if HasVerifiedRoutedPath($h, \mathcal{G}$) **then**
  $\mathbf{v}_{\text{cand}}$.MAV $\leftarrow$ Network
  $\mathcal{K} \leftarrow \mathcal{K} \cup$ {"MAV:N - verified routed reachability"}
else
  return `HUMAN_REVIEW_REQUIRED`
end if
if HasFirewallOrWafEvidence($h, \mathcal{V}_{\text{evidence}}$) **then**
  $\mathcal{K} \leftarrow \mathcal{K} \cup$ {"firewall/WAF recorded; MAC unchanged by presence alone"}
end if
if ExploitPreconditionsSupportHighComplexity($\mathcal{V}_{\text{evidence}}$) **then**
  $\mathbf{v}_{\text{cand}}$.MAC $\leftarrow$ High
end if ▷ Organization-specific requirements
if HasApprovedRequirementMapping($\Pi, \mathcal{V}_{\text{evidence}}$) **then**
  (CR, IR, AR) $\leftarrow$ ApplyVersionedPolicy($\Pi, \mathcal{V}_{\text{evidence}}$)
  $\mathcal{K} \leftarrow \mathcal{K} \cup$ {"versioned organizational requirement policy"}
end if
$\mathbf{v}_{\text{env}} \leftarrow$ SynthesizeCanonicalVector($\mathbf{v}_{\text{source}}, \mathbf{v}_{\text{cand}}$)
$S_{\text{env}} \leftarrow$ ComputeCVSS40Pinned($\mathbf{v}_{\text{env}}$)
$S_{\text{source}} \leftarrow$ ComputeOrPreserveSourceScore($\mathbf{v}_{\text{source}}$)
$\Delta_{\text{score}} \leftarrow$ round($S_{\text{env}} - S_{\text{source}}, 1$)
return $\mathbf{v}_{\text{env}}, S_{\text{env}}, \Delta_{\text{score}}, \mathcal{K}$

3.4 Formal Topological Inference for Modified Attack Vector (MAV)

A critical requirement of scientific rigor is to avoid conflating the absence of direct public Internet exposure with MAV:Local or MAV:Adjacent. An internal corporate server that

lacks an external IPv4 address but is accessible across enterprise L3 routed subnets remains vulnerable via MAV:Network.

Table 3.1 establishes the formal topological inference matrix implemented in the HelpUS engine.

Table 3.1: Evidence-oriented reachability conditions for candidate Modified Attack Vector (MAV) recommendations. FIRST remains the normative semantic source.

Reachability condition	**Observed evidence**	**Candidate**	**Rationale / limitation**	**Evidence strength**
Remotely routable service	Verified routed path from an allowed remote network to the vulnerable service	MAV:N	Network does not mean "public Internet"; internal routed reachability may still satisfy Network semantics	Direct
Adjacent-only domain	Verified absence of L3 routing and requirement to join the same constrained L2/proximity domain	MAV:A	Use only when the attack truly requires adjacency under the FIRST definition	Strong
Local execution context	Service/component is not remotely reachable and exploitation requires local execution/access on the vulnerable system	MAV:L	Physical access is a distinct MAV:P case	Direct
Physical interaction	Exploitation requires physical manipulation of the vulnerable component	MAV:P	Must be supported by vulnerability semantics, not inferred from network isolation alone	Direct
Ambiguous / incomplete	Partial routes, stale telemetry, unresolved NAT/VPN/firewall state, or conflicting evidence	*Abstain*	`HUMAN_REVIEW_REQUIRED`; preserve source priority rather than downgrade	Insufficient

3.4.1 Conservative Fail-Safe and Abstention Policy

In security-critical operations, an erroneous vulnerability downgrade introduces material security blind spots. Therefore, the HelpUS decision engine enforces a **Conservative Fail-Safe Policy**:

$$\text{Missing}(\mathcal{V}_{\text{evidence}}) \vee \text{Stale}(\mathcal{V}_{\text{evidence}}) \vee \tag{3.2}$$

$$\text{Insufficient}(\mathcal{V}_{\text{evidence}}) \vee \text{Conflicting}(\mathcal{V}_{\text{evidence}}) \implies \text{Status} \leftarrow \texttt{HUMAN_REVIEW_REQUIRED}. \tag{3.3}$$

Under this policy, incomplete, stale, unknown, or contradictory evidence causes automated inference to abstain. Automatic downgrade remains disabled and a human review is required before an operational disposition is approved.

3.5 Exact Combinatorial Optimization for What-If Target Remediation

Conventional vulnerability management operates strictly in forward mode: given observed controls, it calculates the residual risk. HelpUS introduces the **What-If Target Remediation Solver**, which answers the operational engineering question: *What is the exact minimal-cost*

set of compensating controls required to drive the environmental score below an organizational risk ceiling θ_{target}?

Formally, let $\mathbf{U} = \{c_1, c_2, \ldots, c_m\}$ denote the finite universe of deployable compensating controls (e.g., VLAN microsegmentation, WAF virtual patching, egress proxy restriction, credential rotation, service isolation). Each control c_i has an associated operational disruption cost $w(c_i) \in \mathbb{R}^+$. The optimization problem is formulated as:

$$\begin{aligned} \min_{\mathbf{c} \subseteq \mathbf{U}} \quad & \sum_{c_i \in \mathbf{c}} w(c_i) \\ \text{subject to} \quad & S_{\text{env}}(\mathbf{c} \cup \mathcal{V}_{\text{active}}) \leq \theta_{\text{target}} \end{aligned} \tag{3.4}$$

where θ_{target} is an organization-configured contextual-severity ceiling. Example thresholds may be used in experiments, but they are not universal risk standards.

3.5.1 Exact Global Optimality via Exhaustive State Enumeration

Unlike heuristic approximations that risk sub-optimal local minima, the HelpUS solver leverages the fact that the universe of viable architectural controls for a single workload is finite and bounded ($m \leq 8$, comprising $2^m \leq 256$ candidate subsets).

For the bounded candidate-control universe ($m \leq 8$), the solver can enumerate at most 256 subsets. Runtime is treated as an empirical property of the implementation and hardware and is reported only from a documented benchmark; no universal sub-millisecond timing claim is assumed here:

$$\mathbf{c}^* = \arg \min_{\mathbf{c} \in \mathcal{P}(\mathbf{U})} \left\{ \sum_{c_i \in \mathbf{c}} w(c_i) \;\middle|\; S_{\text{env}}(\mathbf{c} \cup \mathcal{V}_{\text{active}}) \leq \theta_{\text{target}} \right\} \tag{3.5}$$

Within the explicitly enumerated candidate-control universe and stated cost function, exhaustive search identifies a global minimum-cost feasible subset. This does not imply global optimality over controls that were not represented in $\mathbf{U}$, and all recommended controls remain subject to validation and human approval.

3.6 Policy-as-Code Virtual Patching Synthesis

When software vendors require weeks to release official source-code patches, organizations face severe zero-day exposure windows. The HelpUS engine addresses this by synthesizing executable **Policy-as-Code Virtual Patches** directly from the CVSS vector decomposition.

Depending on detected network topology and service protocol, the engine synthesizes deterministic firewall and proxy candidate rules:

1. **Linux Host-Level Packet Filtering (`iptables`):** Drops non-internal traffic destined to vulnerable daemon ports:

```
iptables -A INPUT -p tcp --dport 8080 ! -s 10.0.0.0/8 -j DROP
```

2. **Cloud Infrastructure Security Groups (AWS CLI):** Revokes wide-open ingress rules (0.0.0.0/0) on public interfaces and tightens security group scopes.

3. **Edge Application Layer Defense (Cloudflare WAF):** Synthesizes JSON filter expressions targeting exploit signatures in HTTP headers and URI payloads.

To ensure operational stability, synthesized virtual patches are treated as **candidate compensating controls**: they undergo static syntax validation, blast-radius reachability simulation, and mandatory Human-in-the-Loop review before deployment into production.

3.7 Exploratory Reachability-Adjusted EPSS Model (Future Work)

The production scoring pipeline is centered on source CVSS and HelpUS-derived Environmental CVSS. A separate exploratory model considers combining EPSS with reachability evidence; it is not part of the confirmatory contribution. For historical comparison, the following notation may be used descriptively:

$$\mathbf{T} = \begin{bmatrix} S_{\text{base}}^{\text{v3.1}} & S_{\text{base}}^{\text{v4.0}} & S_{\text{env}}^{\text{AI}} \end{bmatrix}^T \tag{3.6}$$

Furthermore, while the Exploit Prediction Scoring System (EPSS) [4] provides a global probability $P(E_{\text{wild}})$ of in-the-wild exploitation, it ignores local perimeter reachability. An unauthenticated RCE on a host with zero network access has virtually zero practical exploitation probability.

A future-work prototype may compute a **Reachability-Adjusted EPSS heuristic** via:

$$P(E_{\text{local}}) = P(E_{\text{wild}}) \times \Phi(\mathcal{G}_{\text{reachability}}) \tag{3.7}$$

where $\Phi(\cdot)$ is an explicitly heuristic exposure factor. Until calibrated against outcome data, the quantity must not be interpreted as a Bayesian posterior or calibrated exploitation probability and is excluded from the primary held-out evaluation.

Chapter 4

Dynamic Network Scanning and Topology Inference

4.1 Real-Time Discovery Pipeline

Static vulnerability databases fail to capture dynamic network reconfigurations. To ground the environmental assessment in physical reality, the HelpUS platform integrates an active network interrogation and topology discovery module.

The discovery subsystem interrogates target subnets across four distinct operational modes:

1. **Local Host Probe:** Interrogates the operator or visitor environment via native browser capabilities, client platform hints, and local socket probes to establish identity and loopback boundary.
2. **Subnet CIDR Range Sweep:** Scans arbitrary private subnets (e.g., 192.168.0.0/24, 10.0.0.0/16) via concurrent socket connections across standard enterprise service ports (HTTP 80/443, SSH 22, PostgreSQL 5432, RDP 3389, MySQL 3306).
3. **Enterprise Presets:** Documented baseline topologies including PCI-segmented cardholder environments, DMZs, and network-isolated clinical intranets. These presets are controlled fixtures for development and demonstration, not independently validated production topologies.
4. **Audit JSON Ingestion:** Direct consumption of Nmap, OpenVAS, or Qualys output artifacts for automated continuous integration.

4.2 Topology Inference and Attack Surface Mapping

Once active hosts and open listener ports are discovered, the topology engine derives the reachability graph:

$$\mathcal{G} = (\mathcal{V}_{\text{nodes}}, \mathcal{E}_{\text{edges}}) \tag{4.1}$$

where nodes $\mathcal{V}_{\text{nodes}}$ represent gateways, firewalls, and workloads, and edges $\mathcal{E}_{\text{edges}}$ represent verified routing paths.

4.2.1 Exposure Classification Logic

A host $h \in \mathcal{V}_{\text{nodes}}$ is classified based on routing and perimeter boundaries:

- **Direct Internet Exposure ($I_{\textbf{exposed}} = \textbf{true}$):** Verified inbound path from an external network to a service bound on an Internet-routable address or explicitly published through a gateway/NAT. The CIDR 0.0.0.0/0 denotes the IPv4 default route/address set and is not itself a host address.
- **Segmented Subnet ($N_{\textbf{segmented}} = \textbf{true}$):** Workload located behind a stateful gateway or VLAN tag, requiring intra-subnet lateral movement for exploitation.
- **Local Loopback ($I_{\textbf{exposed}} = \textbf{false}, N_{\textbf{segmented}} = \textbf{true}$):** Service bound strictly to loopback/IPC with no verified remote listener. This supports a local-reachability hypothesis only when vulnerability semantics are consistent with local exploitation.

4.3 Throughput and Latency Performance

The current implementation records engine-level timings, but the manuscript does not present them as a controlled speedup against historical human analysis because the quantities were collected under different protocols. A publication-quality latency benchmark should report the engine hardware/software environment, repeated runs, and distributional statistics (for example median and p95), and should compare equivalent end-to-end tasks.

4.4 Next-Generation Firewall (NGFW) Telemetry Ingestion

While active port sweeping identifies live listener sockets, enterprise defense in depth relies fundamentally on stateful packet inspection, Intrusion Prevention Systems (IPS), and layer-7 application firewalls. To bridge passive logs with active prioritization, HelpUS defines an ingestion adapter for structured Next-Generation Firewall (NGFW) and IDS telemetry. Production validation against specific vendors must be documented separately with versioned artifacts before it is claimed as an empirical result.

Let $\mathcal{L} = \{\ell_1, \ell_2, \ldots, \ell_k\}$ represent the stream of structured firewall event records. Each event ℓ_i is represented by the tuple:

$$\ell_i = \langle \text{timestamp}, \text{IP}_{\text{src}}, \text{IP}_{\text{dst}}, \text{port}_{\text{dst}}, \text{proto}, \text{action}, \text{threat_id}, \text{rule_name} \rangle \tag{4.2}$$

where $\text{action} \in \{\text{allow}, \text{deny}, \text{drop}, \text{reset}\}$.

The topology engine correlates vulnerability listener ports with directional firewall session statistics:

$$\Psi(h, p) = \frac{\sum_{\ell \in \mathcal{L}} \mathbb{I}(\text{dst} = h \wedge \text{port} = p \wedge \text{action} = \text{allow})}{\sum_{\ell \in \mathcal{L}} \mathbb{I}(\text{dst} = h \wedge \text{port} = p)} \tag{4.3}$$

If $\Psi(h, p) = 0$ over a defined observation window, the result is stored as evidence that no allowed sessions were observed in that telemetry source during that period. It does *not* by itself prove absence of reachability and does not directly transform MAV:Network into MAV:Adjacent or MAV:Local. MAV changes require corroborating topology and vulnerability-semantic evidence; incomplete observations trigger the fail-safe review policy.

Chapter 5

Human-in-the-Loop (HITL) Governance and Regulatory Alignment

5.1 The Imperative of Human Oversight in AI Security Systems

While automated AI evaluation provides unprecedented speed, fully autonomous risk prioritization in cybersecurity introduces critical systemic vulnerabilities. If an algorithm erroneously downgrades a critical zero-day vulnerability without oversight, the resulting exposure window could precipitate catastrophic compromise.

To reduce uncritical automation and "rubber-stamping", the HelpUS Framework implements a formalized **Human-in-the-Loop (HITL) Review Gate**. The workflow is designed to support governance practices discussed in the following standards and guidance; this document does not claim that the workflow alone establishes compliance:

1. **NIST AI Risk Management Framework (AI RMF 1.0)** [5]: provides risk-management guidance relevant to transparency, accountability, and human oversight.
2. **ISO/IEC 27001:2022** [6]: provides an information-security management framework within which documented risk-assessment and treatment processes can be governed.
3. **NIST SP 800-40 Rev. 4** [7]: provides enterprise patch-management planning guidance relevant to prioritization and compensating controls.

5.2 The 4-Step Homologation Workflow Protocol

The review gate transitions the AI proposal from a mathematical hypothesis into an auditable organizational decision through a 4-step wizard protocol:

5.2.1 Formal Audit Hash Generation and Merkle Chain

To provide tamper-evident provenance, the implementation hashes a structured audit payload after deterministic JSON canonicalization rather than concatenating free-form fields:

$$H_{\text{audit}} = \text{SHA256}(\text{Canonicalize}(\text{AuditPayload}))\,. \tag{5.1}$$

The payload binds the source assessment, evidence references, candidate metrics, contextual result, operational-policy identifier/version, review state, and timestamp. The current Web

Step 1: Grounding Verification Checklist
Analyst confirms physical facts: VLAN segmentation, firewall restriction, PCI boundary.

⇓

Step 2: Technical Attribution & Identification
The production deployment must bind a reviewer identifier, authorized role, and incident/change ticket through an authenticated authorization path; the scientific artifact treats authorization enforcement as a separately testable control.

⇓

Step 3: Formal Risk Justification
Selection of disposition: Full Approval, Conditional Approval, Rejection (keep NVD), Escalation.

⇓

Step 4: Cryptographic Stamping & Receipt Issuance
Generates a deterministic audit receipt binding evidence, reviewer identity, timestamp, and decision. Digital signature is a separate optional control when an approved key infrastructure is available.

Figure 5.1: The HelpUS 4-Step Human-in-the-Loop Homologation Pipeline.

implementation is described as *JCS-compatible*; a formal RFC 8785 conformance claim remains contingent on a pinned independent conformance corpus. A hash establishes integrity of the canonical payload, not signer identity or legal non-repudiation.

Records may be inserted into an append-only Merkle-based audit structure so that later modification is detectable. This mechanism provides tamper evidence; it is not, by itself, proof of regulatory compliance, legal non-repudiation, or organizational immutability. Those properties depend on the surrounding identity, key-management, storage, access-control, and governance processes.

5.3 Configurable Operational SLA Policy

Organizations commonly maintain remediation targets that vary by vulnerability severity, asset importance, exposure, threat intelligence, and policy obligations. The HelpUS architecture therefore treats SLA selection as an *organization-configured policy layer*; it does not infer a universal regulatory deadline from a CVSS score alone.

For illustration, a deployment may configure thresholds such as:

$$\mathrm{SLA}_{\mathrm{policy}}(\mathcal{C}) = \begin{cases} 72\ \mathrm{h} & \text{example emergency mapping,} \\ 14\ \mathrm{d} & \text{example expedited mapping,} \\ 30\text{–}60\ \mathrm{d} & \text{example scheduled-remediation mapping.} \end{cases} \tag{5.2}$$

These durations are examples, not statements of a universal PCI-DSS, NIS2, DORA, ISO, or NIST requirement. Any production deployment must version the applicable local policy and retain the policy identifier in the decision provenance.

5.3.1 Economic Modeling as Future Calibration Work

The current monograph does not claim a validated dollar-value reduction in incident cost, hotfix regression rate, or residual exploit probability. Such claims require an independently

sourced and reproducible economic dataset, a documented causal model, and sensitivity analysis. The system can retain fields for implementation cost, operational disruption, and expected-loss modeling, but numerical economic benefits should be reported only after those parameters are empirically calibrated.

Chapter 6

Empirical Evaluation and 30-Scenario Benchmark

6.1 Benchmark Dataset Architecture and Roles

To evaluate the HelpUS framework with scientific rigor, we formalize a multi-dataset architecture that clearly separates historical observation, development calibration, and planned independent validation:

1. **Dataset A1 (Historical Human Benchmark)**: Comprises the $N = 348$ vulnerability evaluations across 29 participants from the Allodi et al. [1] empirical trial. This dataset evaluates CVSS v3.0 in flat vs. segmented topologies and serves exclusively as a historical human-factor baseline.

2. **Dataset B (Development Benchmark, $n = 30$)**: The current 30-scenario testbed comprising 12 real-CVE records embedded in controlled deployment profiles and 18 synthetic scenarios. Dataset B serves strictly for internal architectural verification, debugging, and regression testing during development; it is not presented as confirmatory evidence of external generalization.

3. **Dataset C1 (Independent Diverse Held-Out Set – Planned)**: A prospective evaluation suite of 25–40 unseen enterprise network scenarios conceived independently by external network engineers. Evaluated by blinded independent domain experts to address research question RQ1 (Effectiveness).

4. **Dataset C2 (Adversarial Safety Challenge Set – Planned)**: A prospective stress-testing suite of 20–30 scenarios featuring ambiguous reachability, conflicting telemetry, NAT edge cases, and stale inventories to evaluate RQ2 (Severe False Downgrade Rate) and RQ3 (Fail-Safe Abstention).

6.2 Distinction Between CVSS Severity and Operational Priority

The HelpUS framework maintains an explicit boundary between the technical scoring standard and internal organizational actioning:

- **Technical CVSS Output**: Comprises canonical vector $\text{Vector}_{\text{env}}$, continuous scalar score $S_{\text{env}} \in [0.0, 10.0]$, and standard FIRST qualitative severities: $\text{Severity}_{\text{env}} \in \{\text{None}, \text{Low}, \text{Medium}, \text{High}, \text{Critical}\}$.

- **HelpUS Operational Disposition**: Dispositions reflect organizational operational workflow and are classified into distinct priority tiers:

$$\text{Priority}_{\text{op}} \in \{\text{P0_IMMEDIATE}, \text{P1_EXPEDITED}, \text{P2_SCHEDULED}, \tag{6.1}$$
$$\text{P3_MONITOR}, \text{P4_DEFER_RECOMMENDED}\}. \tag{6.2}$$

  Critically, P4_DEFER_RECOMMENDED is not a CVSS severity level and does not represent automatic risk acceptance. Formal risk acceptance requires documented Human-in-the-Loop approval by an authorized risk owner. Cryptographic signing is a separate optional control that may be applied when a verified signing infrastructure is configured.

Operational dispositions are policy outputs rather than direct extensions of the CVSS severity scale. Any score bands or workflow thresholds used to map a CVSS-BE result to P0–P4 must therefore be defined in an explicit, versioned organizational policy. The framework does not assume a universal mapping from a CVSS score to an operational disposition.

6.3 Statistical Results on Development Benchmark (Dataset B)

Table 6.1 summarizes Dataset B by scenario origin and legacy local development-policy disposition. It intentionally avoids treating CVSS severity and P0–P4 as a single ordinal scale. Source-vector provenance, including the distinction between provider-reported Base values and complete-vector recomputation for CVSS-BT records, is retained separately in the schema-v2 tables in Appendix C. These counts are descriptive development data, not a measure of correctness.

Table 6.1: Dataset B development composition by scenario origin and legacy local operational disposition ($n = 30$). P0–P4 are organization-policy workflow labels, not CVSS severity levels.

Scenario origin	P0	P1	P2	P3	P4	Total
Real-CVE controlled context	1	5	3	3	0	12
Synthetic fixture	8	4	2	0	4	18
Total	9	9	5	3	4	30

6.3.1 Formal Evaluation Metric Formulations

To evaluate safety and abstention without conflating constructs, we formalize the evaluation metrics that govern current observations and prospective held-out trials:

$$\text{FDR}_{\text{CVSS}} = \frac{N(H_s < R_s)}{N(\text{eligible reference scenarios})}, \tag{6.3}$$

$$\text{SFDR}_{\text{CVSS}} = \frac{N(R_s \in \{C, H\} \wedge H_s \in \{M, L, N\})}{N(R_s \in \{C, H\})}, \tag{6.4}$$

$$\text{Abstention Sensitivity} = \frac{N(A \wedge E \in \{I, C\})}{N(E \in \{I, C\})}, \tag{6.5}$$

$$\text{Unsafe Non-Abstention} = \frac{N(D \wedge E \in \{I, C\})}{N(E \in \{I, C\})}. \tag{6.6}$$

Here R_s and H_s denote reference and HelpUS CVSS severity, respectively; A denotes abstention; D denotes an automatic downgrade; and $E \in \{I, C\}$ denotes independently classified insufficient or conflicting evidence.

Table 6.2 provides a descriptive side-by-side comparison across the eight benchmark vulnerabilities evaluated in the complex PCI-DSS segmented scenario ("Christine's Company" [2]).

Table 6.2: Replication-Inspired Benchmark: Historical Human Error Rates [1] and Development-Stage HelpUS Scenario Outputs

CVE ID	Component & Context	Type	Historical Base	Human Error [1]	HelpUS Output / Reference Status
CVE-2016-6441	Cisco IOS Switch (VLAN ACLs)	SYS	9.8	**86.0%**	**Provisional match** (reference adjudication pending)
CVE-2016-6428	Cisco IOS Switch (Core RACL)	SYS	7.8	**90.0%**	**Provisional match** (reference adjudication pending)
CVE-2016-0036	Win Server (RDP / Backend)	SYS	8.8	**76.0%**	**Provisional match** (reference adjudication pending)
CVE-2016-0469	Oracle Retail MICROS POS	SYS	5.5	**79.0%**	**Provisional match** (reference adjudication pending)
CVE-2016-1619	Chrome (Wireless Guest Subnet)	APP	7.6	**83.0%**	**Provisional match** (reference adjudication pending)
CVE-2016-6792	Chrome (Admin Office Store)	APP	9.8	**86.0%**	**Provisional match** (reference adjudication pending)
CVE-2016-0126	MS Office (Customer Data)	APP	7.8	**10.0%**	**Provisional match** (reference adjudication pending)
CVE-2016-0019	Windows Client (Store POS)	SYS	8.1	**28.0%**	**Provisional match** (reference adjudication pending)
Historical segmented-scenario aggregate				**41.4% error (96/232)**	**8/8 provisional scenario matches**
Core Routing Infrastructure (Cisco Switches)				**88.0% Error**	**2/2 provisional matches**
Timing context				**120-min participant session window**	**680 ms engine timing; not end-to-end comparable**

6.3.2 Resolution of the Infrastructure Attribution Failure

The most pronounced disparity in Table 6.2 occurs in the core routing tier (CVE-2016-6441 and CVE-2016-6428). In manual assessments, between 86% and 90% of human evaluators produced incorrect scores because humans struggled to model the dual identity of a switch:

- When viewed as a *host*, the switch exposes management interfaces bound to Out-of-Band enclaves.
- When viewed as an *intermediary*, the switch enforces Access Control Lists that shield downstream POS cardholder networks.

The historical study reports substantial disagreement on these routing cases. The HelpUS graph engine can evaluate the encoded reachability graph deterministically, but correctness must be established against an independently adjudicated expert reference. Engine micro-timings are reported separately from the historical participant-session duration.

6.4 R6-A1 Experimental Campaign: Schema v2, Governance, Differential, and Transfer

Following the development baseline of Dataset B, the R6-A1 experimental campaign evaluated contract robustness, downstream governance, differential arithmetic concordance, and external transfer:

1. **Closed-World Schema v2 (T2R, T3):** Replaced open-world semantics with closed-world validation (`"additionalProperties": false`). In compatibility testing (T2R), all 30 legacy Dataset B traces were classified as `V1_VALID_V2_INVALID` due to strict typing (12 `INVALID_TYPE`) and enum constraints (18 `INVALID_ENUM`). Replaying the 120-case mutation complement (T3) achieved 120/120 rejections (100.0%), successfully resolving the historical subobject injection gap ($F3$: 16/16 rejections under Schema v2 vs 0/16 under Schema v1).

2. **Novel Mutation Campaign (T4R, NF2-R):** Evaluated six domain-specific mutation families across 15 canonicalized parents ($N = 90$), achieving 75/90 attributable rejections (83.33%), alongside companion experiment NF2-R ($N = 15$) verifying 15/15 rejections of core-field shadowing at the root boundary.

3. **Governance Override Invariants (T5-R, T6):** Verified downstream governance override across eight adversarial fixtures with 8/8 PASS across all invariants (INV-G1–G8). Nominal Equation 8 weights remained invariant, and autonomous overrides were zero. Evaluated representability across four NVD CVEs (12 diagnostic checks), showing 2/4 representable by normative structural transformation and 2/4 requiring new evidence, with zero data invented.

4. **Independent Differential Validation (Differential R2):** Evaluated 486,472 FIRST reference vectors against secondary comparator `cvss4py` (commit `9fe705c`). Decoupled endpoints demonstrated 454,047/461,444 exact numeric concordance (98.3970%) on calculable vectors (all 7,397 mismatches $|\Delta| = 0.1$ and 100% matching FIRST official values) and 25,028/25,028 syntax rejection concordance (100.0%) on malformed vectors under deterministic parity.

5. **External Held-Out Transfer (T7):** Evaluated an external quarantined corpus of $N = 938$ real-world advisories from the GitHub Advisory Database. Classified 339 as nominal-calculable (36.1407%) and executed 599 fail-closed rejections (63.8593%) due to missing mandatory evidence, with zero data invented, zero autonomous overrides, and 938/938 traces validated across 3,232 diagnostic checks.

Independent human expert adjudication remains pending (`human_adjudication_completed = false`), and confirmatory datasets C1/C2 remain sealed under gatekeeper protocol G10B.

Chapter 7

Real-World Operational Case Studies

7.1 Case Study 1: Core Banking PCI-DSS Payment Gateway

7.1.1 Context and Architecture

This controlled fixture models a Tier-1 financial institution operating a transactional payment processing API (`payment-api`) that manages cardholder tokenization. The fixture uses a fixed source CVSS assessment for architecture testing; it is not presented as a claim about a particular live incident or provider-published CVE record.

7.1.2 Environmental Telemetry

- **Internet Exposure:** False (restricted to internal PCI VLAN).
- **Segmentation:** Stateful gateway with strict ingress/egress filtering.
- **Regulatory Scope Evidence:** PCI-DSS in-scope; no CVSS requirement value follows automatically from this fact.
- **Organizational Requirements Policy:** Example policy `ORG-POL-PCI-v1` maps the documented confidentiality and transaction-integrity requirements to CR:H and IR:H for this fixture.

7.1.3 HelpUS Evaluation vs. Legacy Scoring

This controlled case illustrates how the system can recommend a candidate Environmental vector from verified reachability and a versioned organizational requirements policy. The resulting CVSS-BE score must be produced by the pinned specification-conformant calculation stage. Any CR/IR settings are treated as organization-approved mappings rather than values mandated by PCI-DSS itself. The example score is therefore a benchmark output that must remain traceable to the exact input vector and calculator version.

7.2 Case Study 2: Network-Isolated Medical Clinic Workstation

7.2.1 Context and Architecture

This controlled fixture models a private outpatient healthcare clinic hosting a local PostgreSQL database containing electronic health records (EHR). It represents an SQL-injection scenario with a fixed benchmark source assessment; the fixture is illustrative and is not presented as a provider-published CVSS v4.0 assessment for a specific CVE.

7.2.2 Environmental Telemetry

The host is physically attached to the clinic's local Ethernet switch behind a commercial NAT router with no port forwarding configured. The service is bound to the internal subnet ($192.168.0.x$) with local authentication.

7.2.3 HelpUS Evaluation vs. Legacy Scoring

A source-only workflow may overemphasize intrinsic vulnerability characteristics when local reachability evidence is unavailable. The HelpUS AI Watcher records the observed routing boundary and proposes a candidate Environmental vector. A NAT router with no port forwarding establishes lack of direct inbound Internet publication, but it does not by itself prove MAV:Adjacent; the adjacent-network recommendation requires corroborating routing evidence. The final score and operational disposition must be generated from the canonical vector and the organization's approved SLA policy.

7.3 Case Study 3: Public Cloud E-Commerce Storefront

7.3.1 Context and Architecture

This controlled fixture models a direct-to-consumer e-commerce storefront published on TCP/443 through a public cloud ingress path and affected by a critical deserialization flaw represented by a fixed benchmark source assessment. The host operates without an edge Web Application Firewall (WAF) or IP reputation rate-limiting.

7.3.2 HelpUS Evaluation

Because the controlled scenario specifies verified public reachability and no modeled perimeter control, the HelpUS engine preserves a Network-reachable candidate state and applies the configured organizational requirements. The final score is obtained from the canonical CVSS-BE vector; any escalation ticket is a policy action, not a prediction that exploitation will occur.

7.4 Case Study 4: Enterprise Infrastructure — Resolving the Cisco Switch Dilemma

7.4.1 The Dilemma Identified in Empirical Literature

In the controlled experiment by Allodi et al. [1], the single highest failure rate occurred when evaluators were asked to score core routing infrastructure implementing VLAN Access Control Lists (Cisco IOS Transaction Language 1 defect CVE-2016-6441 and CVE-2016-6428 in the

historical CVSS v3.0-era study). Over **86% to 90% of human evaluators failed this assessment**, incorrectly classifying whether the defect exposed the internal POS networks or was mitigated by intermediate management enclaves.

7.4.2 HelpUS Topological Graph Evaluation

The HelpUS framework consumes the verified infrastructure model $\mathcal{G} = (\mathcal{V}, \mathcal{E})$ from active SNMP/LLDP telemetry and configuration files:

- **Target Node:** Core Cisco ASR Aggregation Switch (h_{core}).
- **Interface Inspection:** The vulnerability exists in the management plane daemon (port 3082/TCP TL1 and SSH/Telnet).
- **Reachability Analysis:** The discovery engine verifies that the switch management interface is bound strictly to a dedicated Out-of-Band (OOB) VLAN (10.254.0.0/24) accessible exclusively via an authenticated Bastion VPN with hardware tokens.
- **Data Plane Segregation:** The customer cardholder data plane traverses ASIC hardware switching pipelines isolated from the vulnerable control software.

7.4.3 Contextual Vector Computation

The revised pipeline does not assign manual score deltas to individual metrics. It records the source vector, derives only evidence-supported candidate Environmental metrics, synthesizes a canonical CVSS v4.0 vector, and invokes the specification-conformant calculator:

$$\mathbf{v}_{\text{source}} \longrightarrow \mathbf{v}_{\text{candidate-env}} \tag{7.1}$$

$$\longrightarrow \mathbf{v}_{\text{canonical-CVSS-BE}} \tag{7.2}$$

$$\longrightarrow S_{\text{env}}, \qquad \Delta_{\text{score}} = S_{\text{env}} - S_{\text{source}}. \tag{7.3}$$

The exact source vector, source nomenclature, contextual vector, and calculator version must be retained in the replication artifact. Values such as "MAV:A $= -0.8$" or "MPR:H $= -1.2$" are intentionally not used because CVSS v4.0 is not an additive per-metric delta model.

7.4.4 Policy-as-Code Virtual Patching and What-If Optimization

Rather than leaving the engineering team in paralysis over an unpatchable core switch that requires a full firmware reboot during business hours, the HelpUS engine activates its dual operational modules:

1. **What-If Target Solver:** The analyst inputs an operational ceiling of $\theta_{\text{target}} \leq 5.0$. The solver deduces the minimum compensatory control: *Revoke the TL1 management interface listener on all core-facing IP interfaces and bind strictly to the loopback management VRF.*
2. **Candidate Virtual-Patching IaC:** The platform can synthesize a candidate Cisco IOS access-control change. Generation time alone is not a safety claim; syntax validation, reachability simulation, human approval, deployment verification, and rollback are required.

```
ip access-list extended ACL_BLOCK_TL1_EXPLOIT
 permit tcp 10.254.0.0 0.0.0.255 host 10.254.0.1 eq 3082
 deny   tcp any host 10.254.0.1 eq 3082
```

```
 permit ip any any
interface GigabitEthernet0/0/0
 ip access-group ACL_BLOCK_TL1_EXPLOIT in
```

This case illustrates how the architecture converts topological evidence into a reviewable candidate mitigation. It does not claim that an automatically generated ACL is safe or sufficient until the validation and HITL stages have completed.

Chapter 8

Optional Cognitive Assurance Layer

The HelpUS architecture is designed so that the deterministic CVSS processing plane remains fully functional without external artificial-intelligence services. AI integration is therefore treated as an optional assurance and enrichment capability rather than a scoring dependency.

8.1 Architectural Separation

The deterministic plane remains responsible for evidence ingestion, asset-context normalization, environmental rule execution, metric resolution, canonical CVSS vector construction, scalar scoring, prioritization, and operational reporting. The optional HelpUS Cognitive Assurance Layer (HCAL) may inspect exported evidence packages and return structured advisory findings.

The governing invariant is:

AI enhancement must be non-blocking.

Complete AI unavailability must not prevent otherwise valid deterministic processing.

8.2 Operating Modes

HCAL defines three operating modes:

- **Core Autonomous:** no external AI provider is used;
- **Single-AI Augmentation:** one provider reviews an approved evidence package;
- **Multi-AI Assurance:** two or more provider-neutral adapters independently review the same normalized package.

No mode permits an AI provider to become the normative scoring authority.

8.3 Package and Return Contracts

The core may export vulnerability, environment-review, or executive-risk packages containing only the data approved for external analysis. AI responses are normalized into structured findings that include a finding type, evidence references, confidence, and a recommended follow-up action.

Two return classes are distinguished. Non-authoritative returns, such as summaries, explanations, or investigation suggestions, may enrich reports directly when clearly labeled.

Authoritative-candidate returns that could affect a metric must pass independent evidence validation and deterministic policy checks before they are admitted back into the metric-resolution pipeline.

Thus, the allowed path is:

AI finding → evidence validation → policy/rule validation → metric resolver → deterministic CVSS engine.

Direct AI score override is prohibited.

8.4 Multi-Model Review

In multi-model mode, independent providers may produce unanimous, partially overlapping, conflicting, or provider-specific findings. Agreement may raise the priority of a verification task, but AI consensus is not treated as CVSS authority or as a substitute for normative evidence.

Where semantic metric candidates are generated, the existing strict quorum rule applies: exact agreement at the required metric level is necessary for autonomous acceptance. Final score computation remains deterministic.

8.5 Graceful Degradation

Timeouts, provider outages, quota exhaustion, malformed AI responses, or connector failures must degrade only the enrichment layer. The core continues to completion and records the AI-enrichment status as unavailable or skipped.

This provides a testable architectural property: full completion of otherwise valid core cases under total AI outage.

8.6 Security and Privacy

External AI packages must be minimized, sanitized, and logged. Credentials, secrets, and unnecessary internal identifiers must be removed. The architecture should support external providers, private enterprise AI services, and local models through replaceable adapters. Returned data must be schema-validated before use.

8.7 Scientific Evaluation

A secondary research track can compare core-only, single-model, and multi-model configurations. Fault-injection experiments can introduce known inconsistencies such as stale CMDB records, contradictory topology, false mitigation claims, missing dependencies, or poisoned free text. Because the faults are injected by the experiment, their ground truth is known without a human-expert panel.

The principal claim boundary is deliberately narrow: AI may improve anomaly detection, explanation, and contextual evidence discovery while remaining outside the normative scoring function and outside the critical execution path.

8.8 Product Modularity

The same architecture can support distinct product capabilities such as *HelpUS CVSS Autonomous*, *HelpUS CVSS Cognitive Assurance*, and *HelpUS CVSS Multi-AI Assurance*. These capabilities must share the same deterministic scoring guarantees and must not create a dependency on any specific AI brand or provider.

Chapter 9

Discussion, Threats to Validity, and Conclusion

9.1 Discussion of Practical Implications

The implementation of the HelpUS framework addresses the long-standing critique that CVSS Base metrics are inadequate for operational patch prioritization [8, 9]. By separating evidence collection, candidate-metric inference, specification-conformant scoring, and human review, the framework provides a testable architecture for contextual vulnerability prioritization. CVSS remains a severity framework rather than a complete risk model.

Key operational impacts include:

- **Development-Stage Distribution:** Dataset B records source CVSS assessments and local P0–P4 development-policy dispositions as separate constructs. The current development data are not used to claim false-positive suppression, accuracy, or operational risk reduction.
- **Audit Support:** The evidence contract and tamper-evident log can support organizational review and audit preparation; they do not independently establish regulatory compliance.

9.2 Threats to Validity

9.2.1 Construct Validity

Construct validity concerns whether our operational measures accurately reflect the theoretical phenomena under study. First, CVSS Environmental scoring quantifies contextual technical severity rather than full probabilistic operational risk. Second, traceability and deterministic rule execution must not be conflated with decision correctness: a fully audited deduction may still be wrong if the underlying rule is flawed. Third, priority transitions (e.g., reclassifying Base High findings to contextual Medium) reflect model sensitivity, not verified false-positive suppression. Finally, engine micro-timings (milliseconds) cannot be directly compared to historical human session windows (120 minutes) as an experimental speedup factor.

9.2.2 Internal Validity

Internal validity concerns factors that could confound our empirical inferences. Rule definitions may introduce bias if calibrated to the development benchmark (Dataset B). Furthermore, telemetry ingestion risks stale state, partial routing tables, or firewall syntax misparsing. To

mitigate internal validity threats, our planned protocol enforces strict separation between the engine development team and the held-out scenario design team, versioned source records from authoritative CNAs, and mandatory fail-safe abstention (`HUMAN_REVIEW_REQUIRED`) whenever operational evidence is incomplete or conflicting.

9.2.3 External Validity

External validity concerns the generalizability of our findings to operational environments. The development benchmark comprises 30 scenarios (12 CNA-published records and 18 synthetic fixtures). While diverse in design, these development scenarios are not a statistically representative sample and do not establish performance across complex topologies involving carrier-grade NAT, nested VPN overlays, dynamic Kubernetes service meshes, or proprietary industrial/OT protocols. Extending the active scanner with eBPF-based socket telemetry represents a core requirement for generalized production deployment.

9.2.4 Conclusion Validity

Conclusion validity addresses the statistical soundness of relationships inferred from the data. Statistical claims on the 2017 historical benchmark ($p = 4.2 \times 10^{-6}$, OR ≈ 3.4) derive directly from reproducible contingency analysis ($N = 348$). However, inferring broad accuracy or low Severe False Downgrade Rates (SFDR) on small samples is statistically underpowered. Prospective held-out evaluations will employ exact two-sided Clopper-Pearson 95% confidence intervals for all error proportions and non-parametric scenario-level bootstrap ($B = 10,000$) for score deviation metrics.

9.3 Conclusion and Future Research

This monograph has presented the architecture, theoretical formulation, development-stage evaluation, and planned confirmatory protocol for the HelpUS CVSS framework. Following earlier empirical software-engineering work showing that manual CVSS environmental scoring is cognitively demanding and vulnerable to error in complex networks [1], the HelpUS architecture proposes an automated, evidence-constrained alternative whose effectiveness and safety remain to be established on the independent held-out sets.

By combining fact-grounded symbolic inference with candidate Policy-as-Code remediation synthesis, combinatorial What-If optimization, and a rigorous 4-step Human-in-the-Loop review gate, the current implementation establishes several engineering properties while confirmatory effectiveness and safety results remain pending:

- **Deterministic Processing:** Given the same versioned evidence and rule set, the inference stage produces the same candidate metrics, supporting reproducibility.
- **Calculator Conformance Verified (Gate G1 Closed):** A pinned execution of the full official FIRST reference corpus (486,472 test cases across all vector fixtures) against commit `d766d0c` demonstrated exact zero-mismatch concordance. The calculator conformance gate (G1) is formally closed, with Dataset B scores verified and aligned with the specification-conformant engine.
- **Traceable Scoring:** The source assessment, evidence links, candidate metrics, canonical CVSS-BE vector, and calculator output can be retained as separate artifacts.
- **From Scoring to Reviewable Remediation:** The architecture can propose compensating-control configurations, but production deployment remains subject to validation, HITL approval, verification, and rollback.

Future work will expand the active topology scanner to support Kubernetes eBPF service mesh telemetry and integrate formal automated remediation pull-requests into DevSecOps CI/CD pipelines.

Appendix A

Canonical PCI-DSS Enterprise Scenarios

This appendix provides the formal architectural and operational documentation for the canonical Payment Card Industry Data Security Standard (PCI-DSS) network scenarios utilized in the empirical baseline experiment by Allodi et al. [1] and incorporated into the HelpUS evaluation benchmark. The scenarios are derived directly from the authoritative PCI compliance treatise by Williams and Chuvakin [2].

A.1 Scenario 1: Joe's Jumping Jerky Joint (Merchant Level 3)

A.1.1 Organizational Context and Compliance Scope

Joe's Jumping Jerky Joint represents a small distributed merchant operating four brick-and-mortar storefronts alongside an e-commerce website accepting credit card payments. The business was notified by its payment acquirer that it qualifies as a Merchant Level 3 entity, mandating strict compliance validation with the PCI-DSS framework.

Each physical store utilizes IP-based Point-of-Sale (POS) terminals. In the baseline operational state (prior to compliance scoping), these POS terminals share physical and logical network infrastructure with non-payment systems:

- Two store workstations used by managers to browse the web, handle email, and access order fulfillment portals.
- An unmanaged in-store marketing kiosk allowing customers to sign up for mailing lists.
- Unsegmented public Wi-Fi offered freely to customers visiting the store.
- An edge Digital Subscriber Line (DSL) business gateway equipped with DMZ functionality that was initially unconfigured.

A.1.2 Architectural Remediation (After Compliance)

To satisfy PCI-DSS scoping requirements (specifically Requirement 1 regarding firewall configurations and network segmentation), the merchant redeployed the infrastructure as shown in Figure A.1:

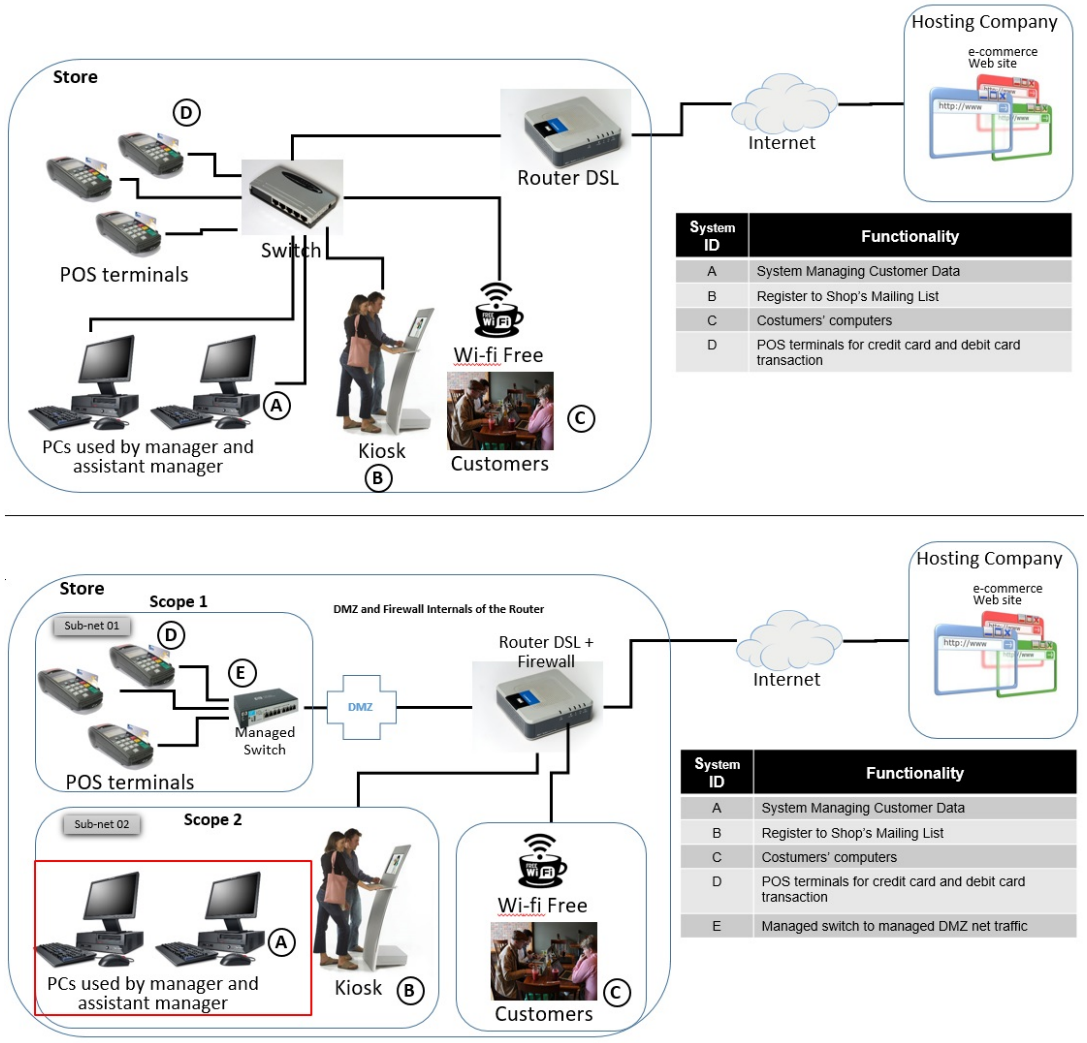


Figure A.1: Architecture of the Level 3 merchant network (Joe's Jumping Jerky Joint) before and after PCI-DSS network segmentation and DMZ enforcement [1, 2].

1. **Isolated POS DMZ Subnet:** The DMZ feature on the edge DSL router is activated. The IP-based POS devices are migrated to a dedicated, isolated physical subnet managed by an independent 8-port managed Ethernet switch.

2. **Access Control and Ingress Filtering:** The DSL gateway firewall rules are locked down: no traffic originated from the administrative workstations, the kiosk, or the customer Wi-Fi is permitted to reach the POS devices or the POS controller.

3. **Complete Wireless Isolation:** Guest Wi-Fi access is isolated into an independent logical broadcast domain with direct egress to the Internet, eliminating any local route to store management systems.

A.2 Scenario 2: Christine's Enterprise (Merchant Level 1)

A.2.1 Organizational Context and Core Switching Architecture

Christine's company is a nationwide retail enterprise that expanded into a Merchant Level 1 organization. An internal security audit revealed that assessors had systematically underestimated the scope of PCI-DSS compliance because the corporate network was historically operated as a flat, unsegmented switching fabric.

Multiple legacy systems not involved in payment processing resided on the core corporate network. Because these legacy systems were no longer maintained by vendor software patches, they could not satisfy baseline PCI requirements.

A.2.2 Multi-VLAN Remediation and RACL Enforcement

To achieve compliance without undertaking a multi-million-dollar replacement of non-payment legacy systems, the enterprise deployed high-density aggregation switches (Cisco ASR series) equipped with hardware-enforced Router Access Control Lists (RACLs) and stateful firewall blades (Figure A.2):

1. **Cardholder Enclave Isolation:** The central payment processing servers and cardholder data repositories are isolated into dedicated VLANs protected by stateful inspection.

2. **In-Store Point-of-Sale Segmentation:** Retail stores enforce RACLs that physically segregate POS terminals from administrative PCs and store kiosks.

3. **Wireless Intrusion Prevention (WIPS):** Rogue access point detection and strict RACLs are activated across wireless access points to prevent air-interface bridging into the wired cardholder network.

4. **Two-Factor VPN Bastion for Operators:** Technical administrators requiring access to cardholder systems are restricted to an Out-of-Band (OOB) management VRF protected by mandatory multi-factor authentication tokens.

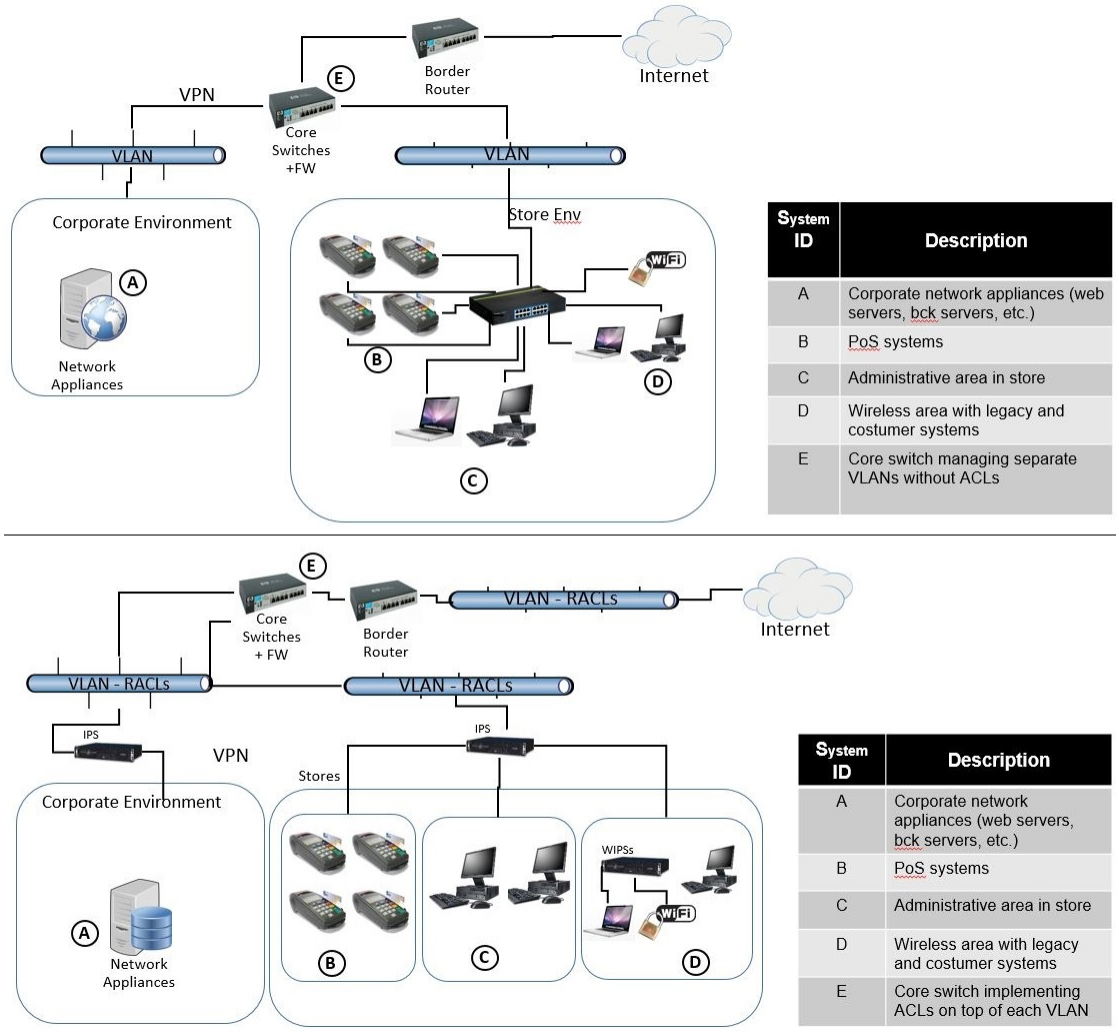


Figure A.2: Architecture of the multi-tier enterprise network (Christine's Company) before and after core multi-VLAN segmentation and Router Access Control Lists (RACLs) [1, 2].

Appendix B

Statistical Methodology and Replication Analysis

This appendix presents the complete mathematical formulations, hypotheses tests, and computational replication procedures underpinning both the historical human evaluator benchmark by Allodi et al. [1] and the HelpUS validation engine.

B.1 Hypothesis Formulation and Fisher's Exact Test

To test whether human evaluators systematically fail when assessing vulnerabilities in complex environments, the evaluation is formalized as a series of 2×2 contingency tables. Let the assessment outcome for any participant evaluating vulnerability v in network context $cxty \in \{\text{Flat}, \text{Segmented}\}$ be a binary random variable $Y \in \{0, 1\}$, where $Y = 1$ denotes agreement with the verified expert standard (correct) and $Y = 0$ denotes disagreement (incorrect).

B.1.1 Network Complexity Hypothesis ($H2$)

The null hypothesis states that the probability of correct assessment is independent of network topology:

$$H2_0 : \quad P(Y = 1 \mid \text{Flat}) = P(Y = 1 \mid \text{Segmented}) \tag{B.1}$$

$$H2_1 : \quad P(Y = 1 \mid \text{Flat}) \neq P(Y = 1 \mid \text{Segmented}) \tag{B.2}$$

Table B.1 summarizes the empirical contingency counts observed across the $n = 29$ evaluator cohort ($N = 348$ total scored instances).

Table B.1: Contingency Table of Assessment Correctness by Network Complexity

Network Architecture	**Correct** ($Y = 1$)	**Incorrect** ($Y = 0$)	**Total**
Flat (Simple)	$a = 96$	$b = 20$	$n_1 = 116$
Segmented (Complex)	$c = 136$	$d = 96$	$n_2 = 232$
Total	$m_1 = 232$	$m_2 = 116$	$N = 348$

Fisher's exact test computes the hypergeometric probability of observing the table marginals under $H2_0$:

$$p = \frac{\binom{a+b}{a}\binom{c+d}{c}}{\binom{N}{a+c}} = \frac{\binom{116}{96}\binom{232}{136}}{\binom{348}{232}} \tag{B.3}$$

The reproducibility script bundled with the project computes the two-sided Fisher exact test and both sample and conditional odds-ratio quantities. The generated values are:

$$p_{\text{Fisher, two-sided}} = 4.2235 \times 10^{-6}, \tag{B.4}$$

$$n\text{OR}_{\text{sample}} = 3.388, \tag{B.5}$$

$$n\text{OR}_{\text{conditional MLE}} = 3.377. \tag{B.6}$$

Using the conditional exact method implemented by the pinned statistical toolchain, the 95% confidence interval is:

$$\text{CI}_{95\%,\text{conditional exact}} = [1.913, 6.184]. \tag{B.7}$$

The method label is reported explicitly because this interval is not the same object as the simple asymptotic Wald interval. The historical null hypothesis of independence is rejected for this contingency table.

B.2 Permutation Two-Way ANOVA for Co-Factor Invariance

To ensure that the human error rate was not driven by individual demographic confounding factors (e.g., years of prior industry experience or self-reported security proficiency), the evaluation executed a non-parametric **Permutation Two-Way ANOVA**.

Let F_{obs} denote the observed test statistic for the interaction between network scenario complexity and participant security experience. The null distribution is generated by randomly permuting the participant labels across $B = 10,000$ resamples:

$$p_{\text{perm}} = \frac{1}{B} \sum_{b=1}^{B} \mathbb{I}\left(F^{(b)} \geq F_{\text{obs}}\right) \tag{B.8}$$

The original participant-level data and complete permutation outputs are required to reproduce this co-factor analysis. Until those artifacts are included, this result should be treated as a historical-study claim rather than a newly reproduced HelpUS result.

B.3 Monte Carlo Dispersal Simulation Algorithm

The synthetic score-space dispersal is generated by Algorithm 2. It is a sensitivity simulation and is not the empirical distribution of human participant scores.

Algorithm 2 Monte Carlo Scoring Dispersal Simulation

Require: Base Score S_{base}, Permutation Count $N = 10,000$, Topology Type $\mathcal{T}$
Ensure: Score Distribution Vector $\mathbf{S}_{\text{dist}}$

$\mathbf{S}_{\text{dist}} \leftarrow \emptyset$
for $i = 1$ to N **do**
    Sample CR $\sim \mathcal{U}\{\text{High}, \text{Medium}, \text{Low}\}$
    Sample IR $\sim \mathcal{U}\{\text{High}, \text{Medium}, \text{Low}\}$
    Sample AR $\sim \mathcal{U}\{\text{High}, \text{Medium}, \text{Low}\}$
    if $\mathcal{T} =$ Segmented **then**
        Sample MAV $\sim \mathcal{U}\{\text{Network}, \text{Adjacent}, \text{Local}\}$
    else
        MAV $\leftarrow$ Network
    end if
    $S_{\text{sim}} \leftarrow \text{ComputeCVSS40}(S_{\text{base}}, \text{MAV}, \text{CR}, \text{IR}, \text{AR})$
    $\mathbf{S}_{\text{dist}} \leftarrow \mathbf{S}_{\text{dist}} \cup \{S_{\text{sim}}\}$
end for
return $\mathbf{S}_{\text{dist}}$

Appendix C

Complete Experimental Datasets

This appendix summarizes the current benchmark corpus. Full computational reproducibility additionally requires machine-readable source vectors, source/retrieval metadata, evidence objects, rule versions, calculator version, scripts, and independent reference labels. Those artifacts should accompany the final paper release.

C.1 Historical 2017 Vulnerability Corpus (Allodi et al.)

Table C.1 documents the complete set of twelve Common Vulnerabilities and Exposures (CVEs) evaluated during the controlled trials across flat and segmented topologies [1].

Table C.1: Historical Vulnerability Dataset from the Allodi et al. [1] Empirical Trial

CVE ID	Affected Software	Target Host	Type	Base	CVSS Vector	Observed Human Error
CVE-2016-0126	Microsoft Office 2016	Customer Data PC	APP	7.8	AV:L/AC:L/PR:N/UI:R	10.0%
CVE-2016-5167	Google Chrome 53	Mailing Kiosk	APP	8.8	AV:N/AC:L/PR:N/UI:R	21.0%
CVE-2016-0019	Windows 10 Workstation	Customer PC	SYS	8.1	AV:N/AC:H/PR:N/UI:N	28.0%
CVE-2016-0067	POS Terminal System	Store POS IP	SYS	7.8	AV:L/AC:L/PR:L/UI:N	10.0%
CVE-2016-0036	Windows Server 2012	Corporate Server	SYS	8.8	AV:N/AC:L/PR:L/UI:N	76.0%
CVE-2016-0469	Oracle Retail MICROS	Retail Store POS	SYS	5.5	AV:L/AC:L/PR:L/UI:N	79.0%
CVE-2016-3234	Microsoft Office 2010	Store Admin PC	APP	5.5	AV:L/AC:L/PR:N/UI:R	45.0%
CVE-2016-6792	Google Chrome 47	Store Admin PC	APP	9.8	AV:N/AC:L/PR:N/UI:N	86.0%
CVE-2016-0012	Microsoft Office 2010	Legacy Wi-Fi PC	APP	4.3	AV:N/AC:L/PR:N/UI:R	34.0%
CVE-2016-1619	Google Chrome 48	Legacy Wi-Fi PC	APP	7.6	AV:N/AC:L/PR:N/UI:R	83.0%
CVE-2016-6441	Cisco IOS XE (ASR 900)	Core VLAN Switch	SYS	9.8	AV:N/AC:L/PR:N/UI:N	86.0%
CVE-2016-6428	Cisco IOS XR	Core VLAN Switch	SYS	7.8	AV:L/AC:L/PR:L/UI:N	90.0%

C.2 Dataset B: 30-Scenario Development Benchmark

Dataset B is a development/regression benchmark rather than a held-out validation set. Its canonical schema separates provider-reported Base values from scores recomputed from the full source vector. This distinction is essential for CVSS-BT records: a provider may publish a Base score while the complete source vector also defines Threat metric E, yielding a different Base+Threat score. The synthetic fixtures also preserve their legacy investigator-assigned scores separately from the current vector recomputation. Several of those legacy assigned scores do not match the score recomputed from their own vectors; the discrepancy is intentionally exposed rather than silently overwritten and must be normalized only after calculator gate G1 closes with the final pinned scorer. The tables below are generated from the schema-v2 machine-readable dataset bundled with this monograph.

Table C.2: Dataset B real-CVE source-assessment provenance (12 development scenarios). Provider-reported Base values are kept distinct from scores recomputed from the complete source vector. Full-vector recomputation remains provisional until calculator gate G1 reaches zero unexplained FIRST-reference mismatches.

Scenario	CVE	Provider	Nom.	Provider Base	Current Full Vector	Full Sev.	Disposition
SCN-NVD-001	CVE-2026-4251	cna@vuldb.com	CVSS-BT	2.0	1.1	Low	P3
SCN-NVD-002	CVE-2026-4252	cna@vuldb.com	CVSS-BT	9.3	8.9	High	P2
SCN-NVD-003	CVE-2026-4270	ff89ba41-3aa1-4d27-914a-91399e9639e5	CVSS-B	6.8	6.8	Medium	P1
SCN-NVD-004	CVE-2026-28490	security-advisories@github.com	CVSS-B	8.3	8.3	High	P0
SCN-NVD-005	CVE-2026-28498	security-advisories@github.com	CVSS-B	8.2	8.2	High	P1
SCN-NVD-006	CVE-2026-29510	disclosure@vulncheck.com	CVSS-B	5.1	5.1	Medium	P3
SCN-NVD-007	CVE-2026-29513	disclosure@vulncheck.com	CVSS-B	5.1	5.1	Medium	P2
SCN-NVD-008	CVE-2026-29520	disclosure@vulncheck.com	CVSS-B	5.1	5.1	Medium	P1
SCN-NVD-009	CVE-2026-29521	disclosure@vulncheck.com	CVSS-B	5.1	5.1	Medium	P1
SCN-NVD-010	CVE-2026-3644	cna@python.org	CVSS-B	6.0	6.0	Medium	P3
SCN-NVD-011	CVE-2026-4224	cna@python.org	CVSS-B	6.0	6.0	Medium	P1
SCN-NVD-012	CVE-2026-4253	cna@vuldb.com	CVSS-BT	5.1	2.0	Low	P2

Table C.3: Dataset B synthetic development scenarios (18 fixtures). The legacy assigned score is retained for provenance; the current vector recomputation exposes inconsistencies that must be resolved after calculator gate G1 closes. Synthetic inputs are investigator-authored and are not CNA/NVD-published assessments.

Scenario	Asset Class	Nom.	Legacy Assigned	Current Recompute	Legacy Sev.	Current Sev.	Disposition
SCN-SYN-013	developer_workstation	CVSS-B	9.3	10.0	Critical	Critical	P0
SCN-SYN-014	isolated_lab_system	CVSS-B	8.7	9.4	High	Critical	P4
SCN-SYN-015	ot_monitoring_gateway	CVSS-B	7.1	8.4	High	High	P0
SCN-SYN-016	public_api_gateway	CVSS-B	6.8	8.4	Medium	High	P0
SCN-SYN-017	public_web_application	CVSS-B	4.8	2.0	Medium	Low	P1
SCN-SYN-018	internal_admin_console	CVSS-B	2.1	1.0	Low	Low	P4
SCN-SYN-019	identity_provider	CVSS-B	9.3	10.0	Critical	Critical	P0
SCN-SYN-020	database_server	CVSS-B	8.7	9.4	High	Critical	P0
SCN-SYN-021	developer_workstation	CVSS-B	7.1	8.4	High	High	P1
SCN-SYN-022	isolated_lab_system	CVSS-B	6.8	8.4	Medium	High	P4
SCN-SYN-023	ot_monitoring_gateway	CVSS-B	4.8	2.0	Medium	Low	P0
SCN-SYN-024	public_api_gateway	CVSS-B	2.1	1.0	Low	Low	P1
SCN-SYN-025	public_web_application	CVSS-B	9.3	10.0	Critical	Critical	P0
SCN-SYN-026	internal_admin_console	CVSS-B	8.7	9.4	High	Critical	P2
SCN-SYN-027	identity_provider	CVSS-B	7.1	8.4	High	High	P0
SCN-SYN-028	database_server	CVSS-B	6.8	8.4	Medium	High	P1
SCN-SYN-029	developer_workstation	CVSS-B	4.8	2.0	Medium	Low	P2
SCN-SYN-030	isolated_lab_system	CVSS-B	2.1	1.0	Low	Low	P4

Bibliography

[1] L. Allodi, S. Biagioni, B. Crispo, K. Labunets, F. Massacci, and W. Santos, "Estimating the Assessment Difficulty of CVSS Environmental Metrics: An Experiment," in *Future Data and Security Engineering (FDSE 2017)*, ser. Lecture Notes in Computer Science, vol. 10646. Springer, 2017, pp. 23–39.

[2] B. R. Williams and A. Chuvakin, *PCI Compliance: Understand and Implement Effective PCI Data Security Standard Compliance*, 4th ed. Syngress / Elsevier, 2014.

[3] FIRST CVSS Special Interest Group, "Common Vulnerability Scoring System v4.0: Specification Document," *Forum of Incident Response and Security Teams (FIRST)*, 2023. [Online]. Available: https://www.first.org/cvss/v4.0/specification-document

[4] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and N. Schwab, "Exploit Prediction Scoring System (EPSS)," *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 1–17, 2021.

[5] National Institute of Standards and Technology, "Artificial Intelligence Risk Management Framework (AI RMF 1.0)," NIST, Tech. Rep. NIST AI 100-1, 2023.

[6] *Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements*, International Organization for Standardization Std. ISO/IEC 27 001:2022, 2022.

[7] S. Murugiah and K. Scarfone, "Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology," National Institute of Standards and Technology (NIST), Tech. Rep. SP 800-40 Rev. 4, 2022.

[8] L. Allodi and F. Massacci, "Comparing Vulnerability Severity and Exploits Using CVSS," *ACM Transactions on Information and System Security (TISSEC)*, vol. 17, no. 1, pp. 1–20, 2014.

[9] J. M. Spring, E. Hatlebak, A. Hou, A. Manion, and D. Agrawal, "Time to Change the Common Vulnerability Scoring System?" *IEEE Security & Privacy*, vol. 19, no. 2, pp. 74–82, 2021.